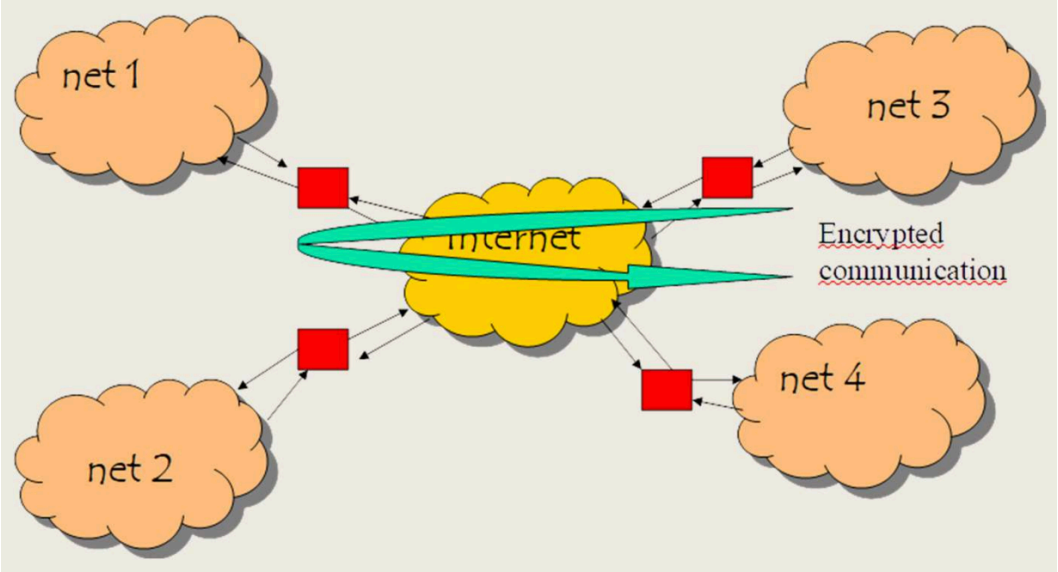
VPN

Description

Virtual Private Network (VPN)

Una **VPN** (Virtual Private Network) è una rete sovrapposta (overlay network) che crea un canale sicuro attraverso una rete pubblica, come Internet, la quale di per sé non è sicura. Attraverso la crittografia e l'autenticazione, la VPN stabilisce una connessione sicura tra sottoreti o tra singoli nodi, rendendo il traffico intercettabile estremamente difficile da comprendere o manipolare da terzi.



Funzioni Principali di una VPN

- **Connessione Sicura**:

  La VPN emula una connessione privata e sicura sopra una rete pubblica. Questo permette a due o più reti locali di essere collegate in maniera sicura, proteggendo tutte le comunicazioni in transito.

- **Crittografia e Autenticazione**:

  Ogni coppia di firewall che protegge una rete locale viene collegata da una VPN, la quale cifra ed autentica tutto il traffico che scorre tra di essi. In questo

modo, anche se un attaccante intercetta i dati, non potrà decifrarli senza le chiavi adeguate.

- **Protezione contro Attacchi DDoS**:

  Una VPN, tuttavia, può essere soggetta ad attacchi DDoS (Distributed Denial of Service). Poiché il traffico viene cifrato, il sistema deve decifrare ogni pacchetto per identificare eventuali dati di "garbage" (messaggi inutili o dannosi) che potrebbero essere inviati per sovraccaricare il sistema.

VPN - IPsec

IPsec (Internet Protocol Security) è un'estensione per IPv4 che offre servizi di cifratura e autenticazione per i flussi di dati. Nonostante l'arrivo di IPv6, IPsec continua a essere rilevante e viene usato "per sempre" in molti contesti, poiché garantisce sicurezza a livello di rete.

Caratteristiche Fondamentali di IPsec

- **Crittografia Simmetrica**:

  Ogni connessione in IPsec viene protetta con algoritmi di crittografia simmetrica, che sono molto efficienti grazie alle operazioni basate sullo spostamento di bit, XOR e ricerche in tabelle. Le chiavi simmetriche vengono aggiornate periodicamente per limitare il danno in caso di compromissione.

- **Scambio di Chiavi Asimmetriche**:

  Per inizializzare una connessione sicura, IPsec utilizza protocolli di scambio di chiavi basati sulla crittografia asimmetrica (come RSA o ECC). Questo permette di stabilire una chiave simmetrica condivisa in maniera sicura, anche se le operazioni asimmetriche sono computazionalmente più lente.

- **Modalità di Operazione: Transport vs Tunnel**

  IPsec può operare in due modi distinti:

  - ***Transport Mode***: Inserisce nuovi campi nel pacchetto originale per garantire autenticazione e, eventualmente, cifratura. Qui l'header IP originale viene mantenuto in gran parte intatto.

    - ***Tunnel Mode*: L'intero pacchetto IP originale viene incapsulato all'interno di un nuovo pacchetto. Questo garantisce che il pacchetto originale (sia header che payload) sia completamente protetto, diventando il contenuto informativo del nuovo pacchetto.

- **Due Principali Protocolli IPsec:**
    - **Authentication Header (AH):** Fornisce autenticazione e integrità dei dati, verificando che il pacchetto non sia stato alterato, ma non offre cifratura del payload.
    - **Encapsulated Security Payload (ESP):** Fornisce cifratura del contenuto per garantire la confidenzialità, e può includere anche meccanismi di autenticazione. Spesso si preferisce ESP per proteggere il contenuto sensibile della comunicazione.

Componenti IPsec

IPsec definisce anche quattro protocolli chiave:

1. **AH (Authentication Header):**

   Autentica i partner e garantisce l'integrità dei dati trasmessi, verificando che i pacchetti non siano stati alterati durante il transito.

2. **ESP (Encapsulating Security Payload):**

   Cifra il contenuto informativo della comunicazione, proteggendo la confidenzialità dei dati.

3. **IKE (Internet Key Exchange):**

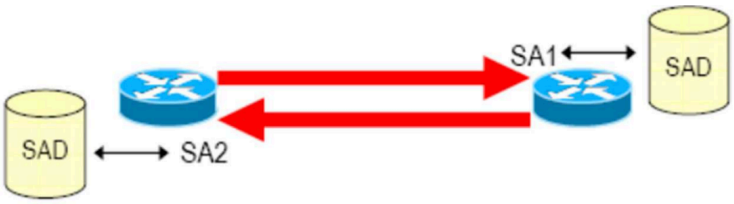
   Permette ai due partner di negoziare in modo sicuro la chiave simmetrica da utilizzare, definendo la durata e le condizioni d'uso della chiave.

4. **ISAKMP (Internet Security Association and Key Management Protocol):**

   Utilizzato per stabilire e aggiornare le **Security Association (SA)**, che descrivono i parametri di sicurezza e le chiavi utilizzate in una specifica connessione.

Security Association (SA)

- Una **Security Association (SA)** è un insieme di parametri che definiscono come due dispositivi comunicano in modo sicuro attraverso IPsec.
- Per una comunicazione bidirezionale sono necessarie due SA, una per ogni direzione.
- La SA include informazioni quali i protocolli di sicurezza (AH o ESP) e le chiavi da utilizzare, garantendo che ogni flusso di dati sia protetto in maniera coerente.



➔ **SPI = Security Parameters Index**

⇨ The (somewhat) unique "name" of an SA

➔ **Destination Address based**

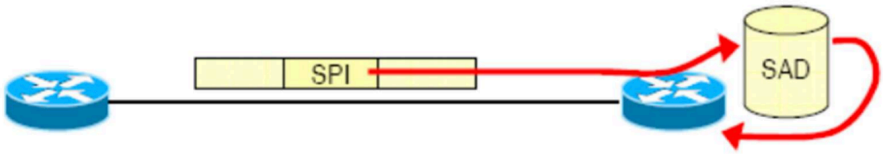
⇨ Security Association managed at the receiver side

➔ **SAD = Security Associations Database**

⇨ SPI = search key (at least)

⇨ Stores set of security services per each SA, and related parameters

➔ E.g. which encryption algorithm; shared key for encryption, SA lifetime, Sequence number counter, etc



➔ **32 bit index**

➔ **Used to lookup the SAD at destination**

⇨ Lookup also uses

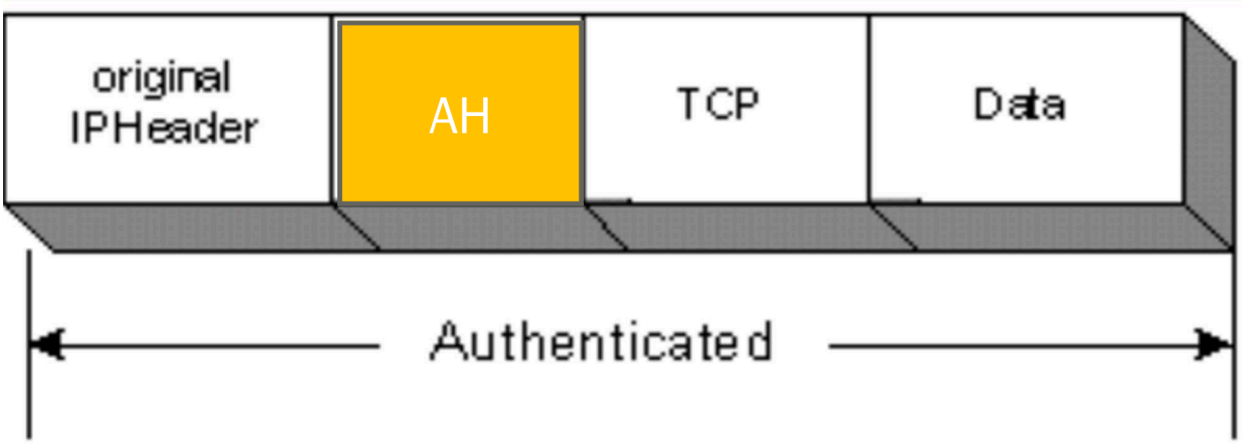
→destination address

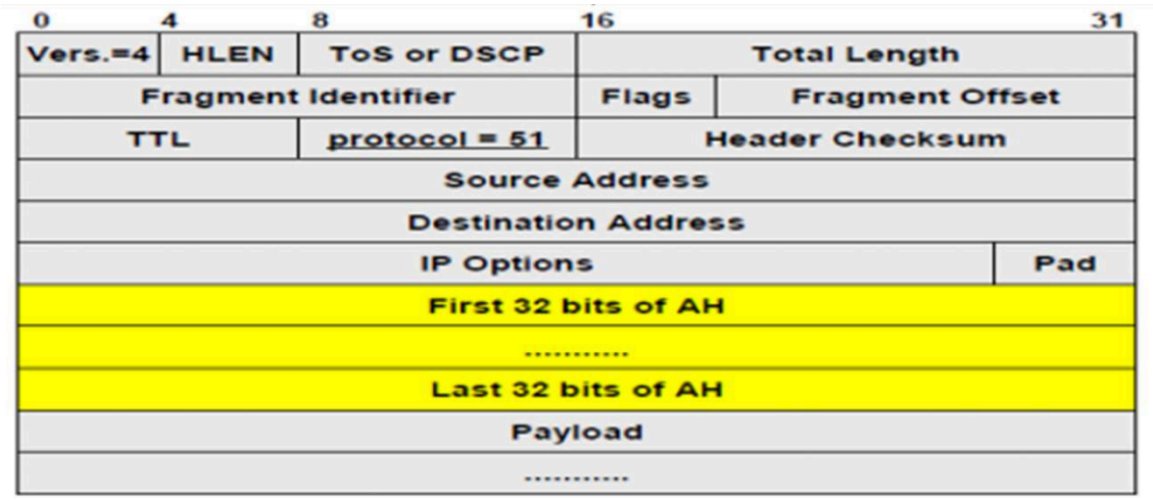
→source address

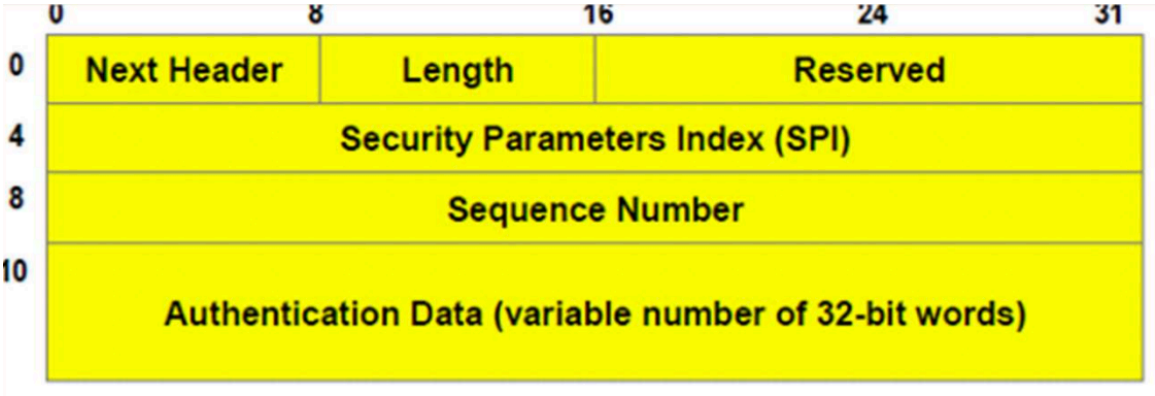
→security protocol (AH/ESP)

➔ **Retrieves algorithms and parameters that allow to process received packet**

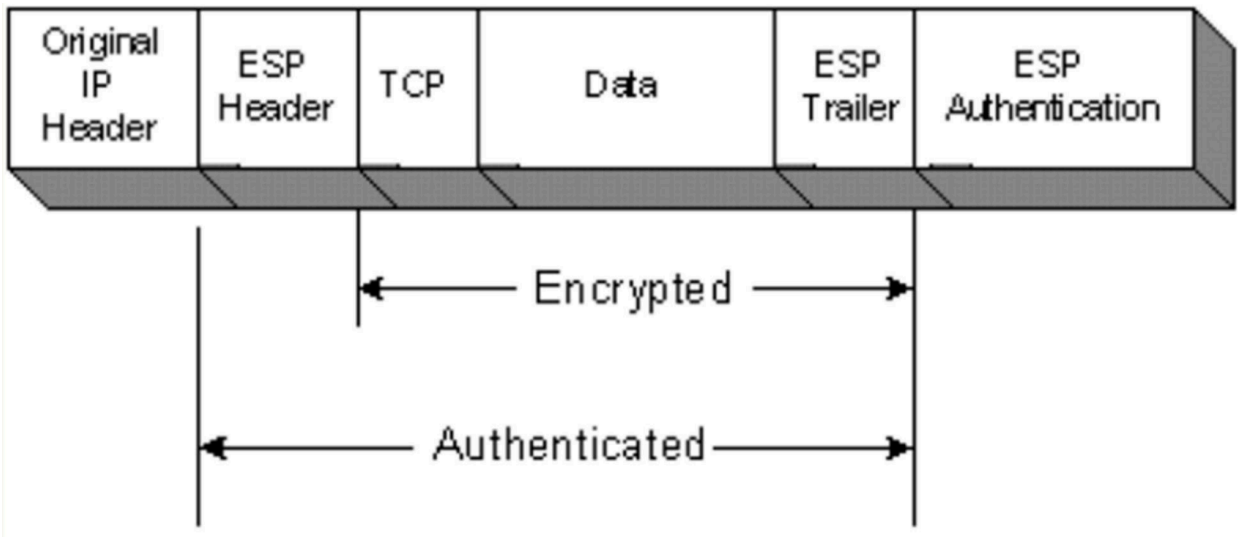
Autenticator Header (AH)

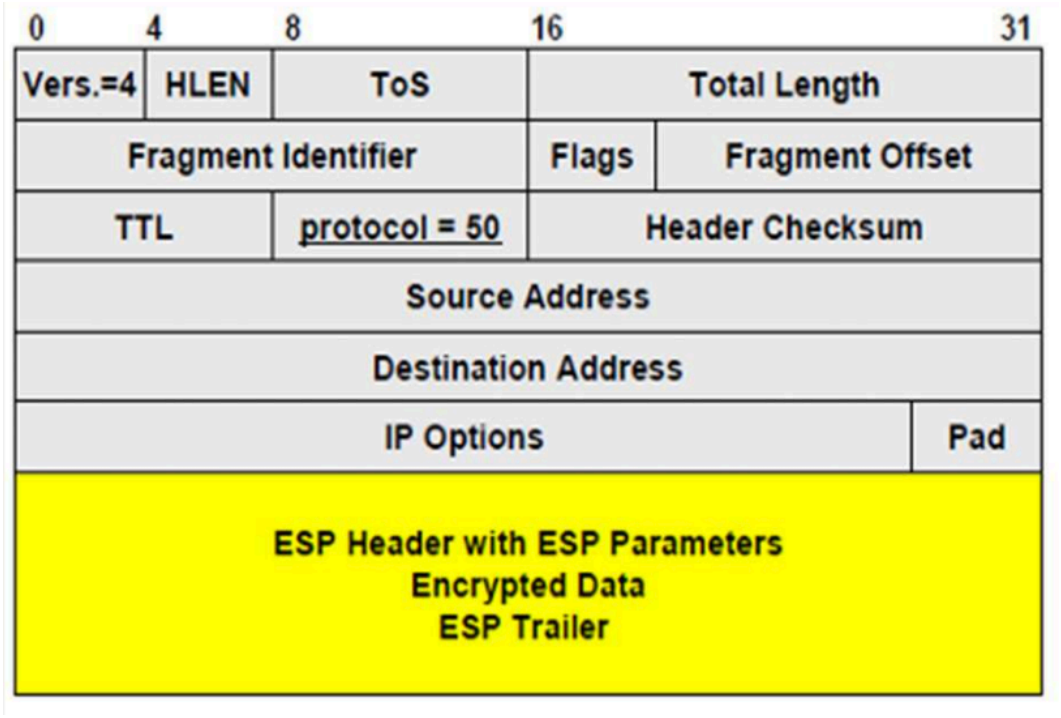


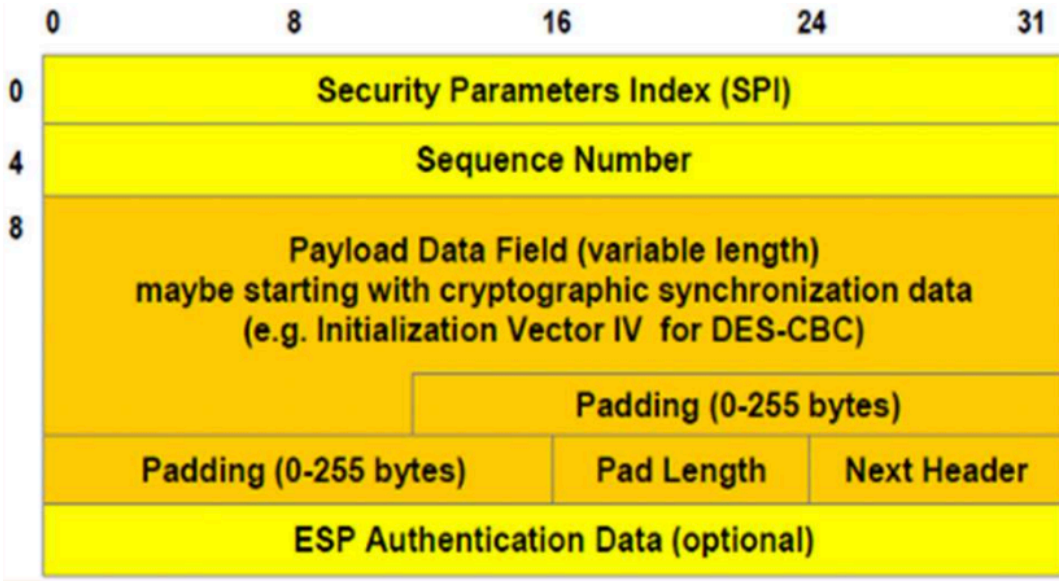


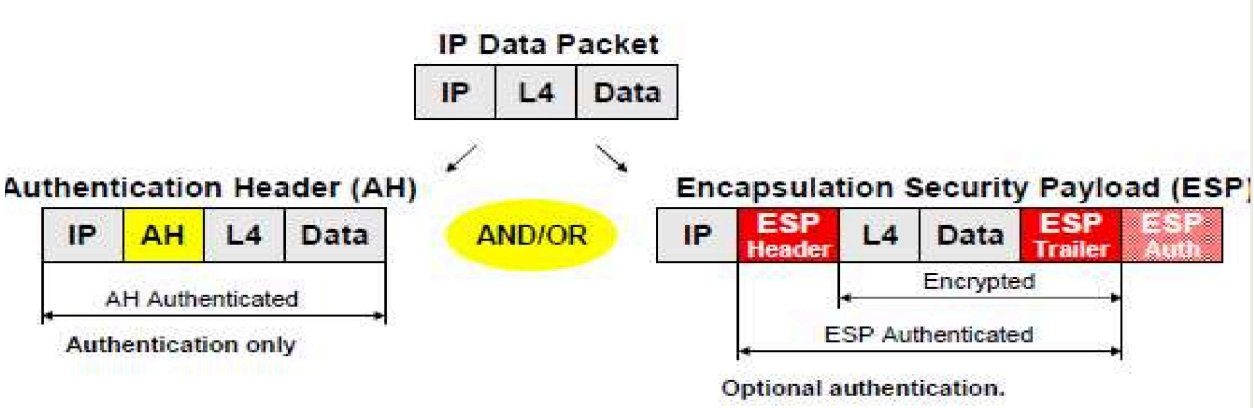


Encapsulating Payload Protocol

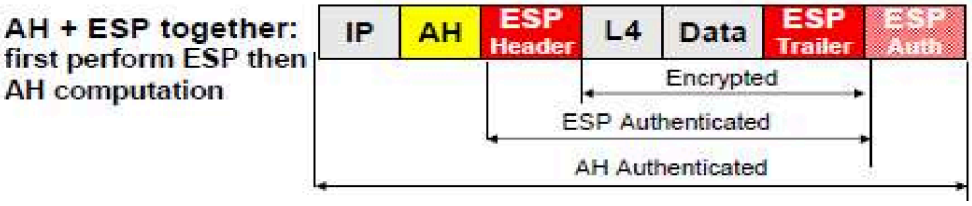



0
4
8
16
31
Vers.=4
HLEN
ToS
Total Length
Fragment Identifier
Flags
Fragment Offset
TTL
protocol = 50
Header Checksum
Source Address
Destination Address
IP Options
Pad
ESP Header with ESP Parameters
Encrypted Data
ESP Trailer


0
8
16
24
31
0
Security Parameters Index (SPI)
4
Sequence Number
8
Payload Data Field (variable length)
maybe starting with cryptographic synchronization data
(e.g. Initialization Vector IV for DES-CBC)
Padding (0-255 bytes)
Padding (0-255 bytes)
Pad Length
Next Header
ESP Authentication Data (optional)



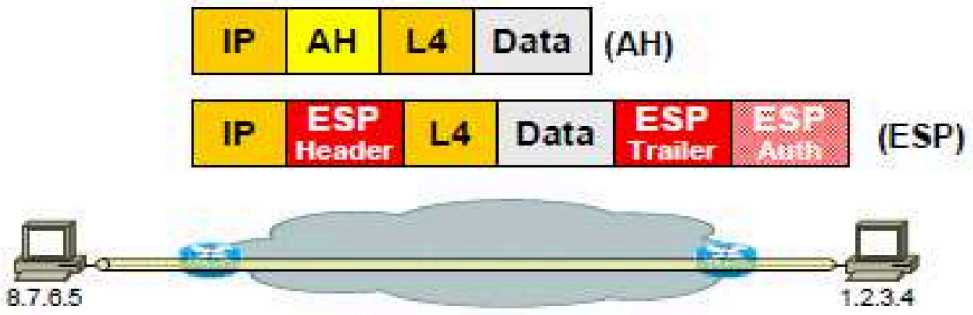
AND possibile ma mai usato

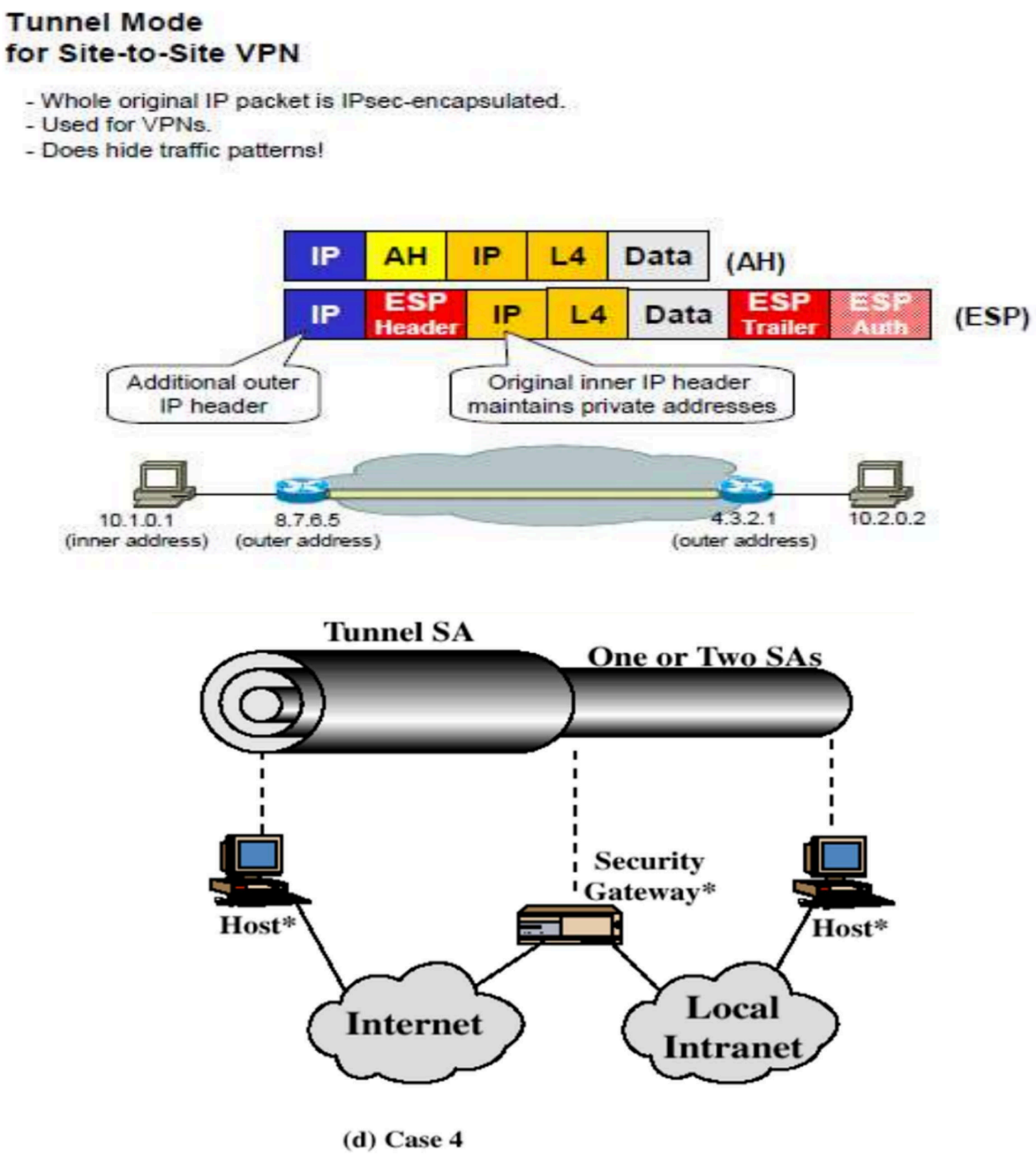


Transport Mode

- Only one IP header.
- Used for end-to-end sessions
- Does not hide communication statistics because of network header (IP addresses of the end systems) is sent in clear text

Possibile traffic analysis e memorizzazione dei metadati



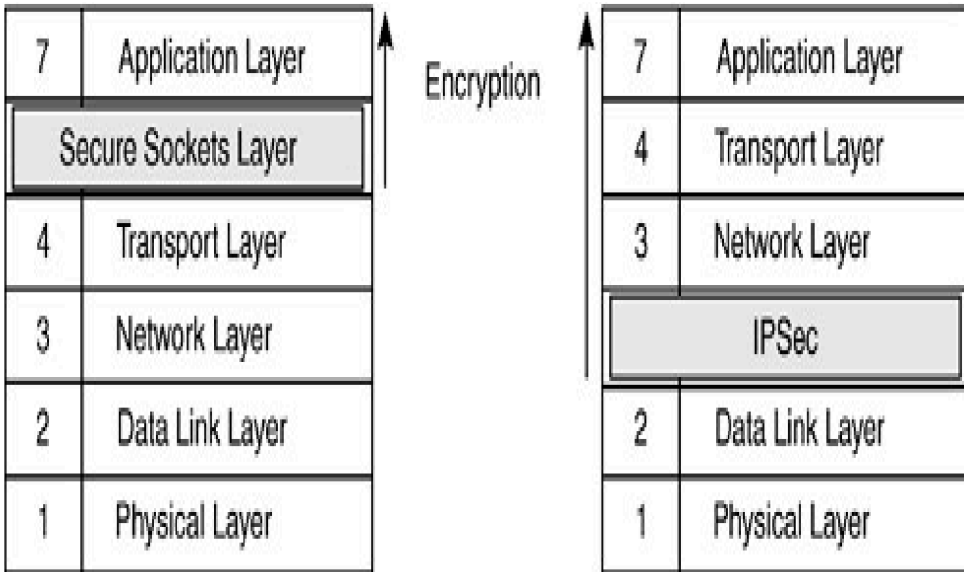


IPsec vs SSL

Mentre **IPsec** opera a livello di rete (OSI Layer 3) proteggendo ogni pacchetto che attraversa la connessione, **SSL/TLS** (e le sue varianti come HTTPS) operano a

livello di trasporto o applicazione, proteggendo le comunicazioni specifiche tra client e server. La scelta tra IPsec e SSL dipende dal contesto applicativo e dai requisiti di sicurezza:

- **IPsec** è ideale per collegamenti tra intere reti (site-to-site VPN) o per proteggere tutto il traffico IP in una connessione.
- **SSL/TLS** è generalmente utilizzato per garantire comunicazioni sicure tra browser e server web o per applicazioni specifiche.



Protezione della Connessione e Aggiornamento delle Chiavi

- La sicurezza di una connessione VPN tramite IPsec è basata sulla combinazione di crittografia simmetrica e asimmetrica. Le chiavi simmetriche, essendo molto efficienti, vengono aggiornate periodicamente per limitare il rischio nel caso in cui una chiave venga compromessa.
- L'uso di algoritmi asimmetrici per lo scambio iniziale delle chiavi assicura che i nodi possano stabilire una connessione sicura senza dover trasmettere segreti in chiaro.

VPN Server e la Garanzia di Confidenzialità

Una questione fondamentale riguarda come garantire la confidenzialità anche rispetto al server VPN, il quale rappresenta il punto di terminazione del tunnel crittografato. Per mantenere elevata la sicurezza, è necessario adottare diverse strategie:

- **Crittografia End-to-End:**

  Il traffico tra il client e il server VPN è completamente cifrato. Ciò significa che, anche se il traffico venisse intercettato, i dati rimarrebbero illeggibili senza le chiavi appropriate.

- **Segmentazione delle Reti:**

  Attraverso l'uso di firewall e altre misure di sicurezza, è possibile isolare il server VPN in una zona demilitarizzata (DMZ) o in una rete separata.

- **Autenticazione Forte:**

  L'impiego di autenticazioni a due fattori, certificati digitali e altre tecniche di autenticazione avanzate garantisce che soltanto le entità verificate possano stabilire una connessione VPN.

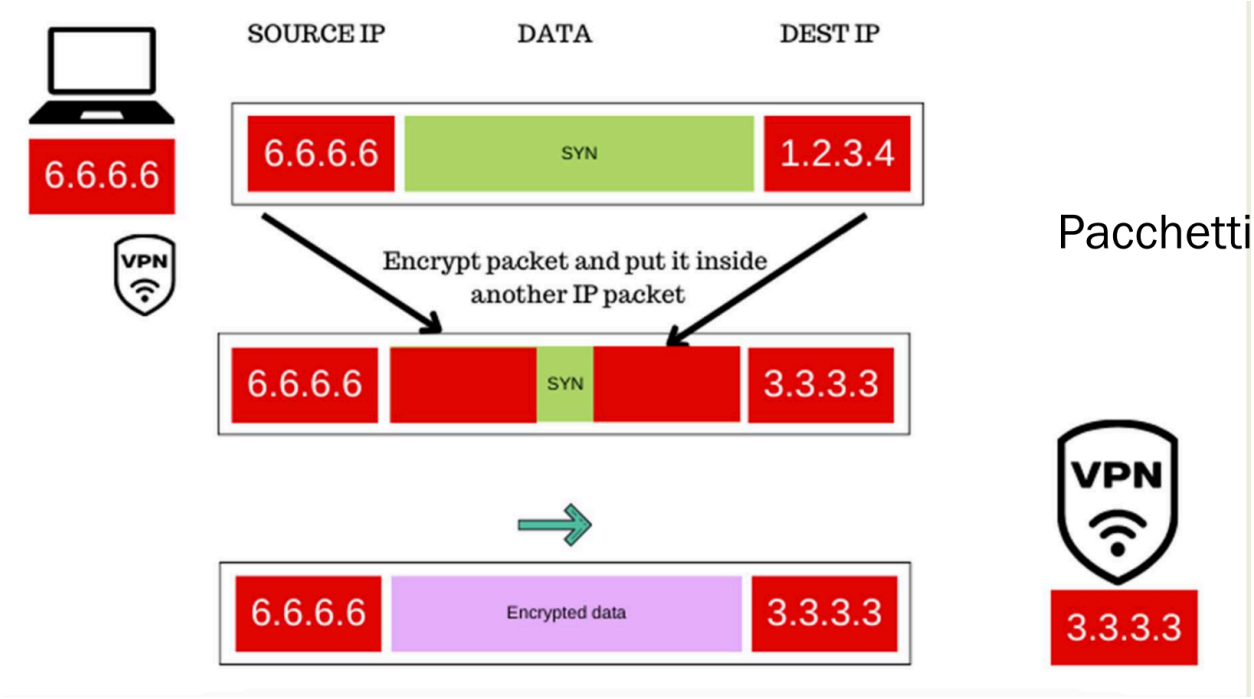
- **Audit e Monitoraggio Continuo:**

  La registrazione dettagliata degli accessi, il monitoraggio continuo e gli aggiornamenti di sicurezza regolari sono essenziali per rilevare e rispondere tempestivamente a eventuali anomalie.

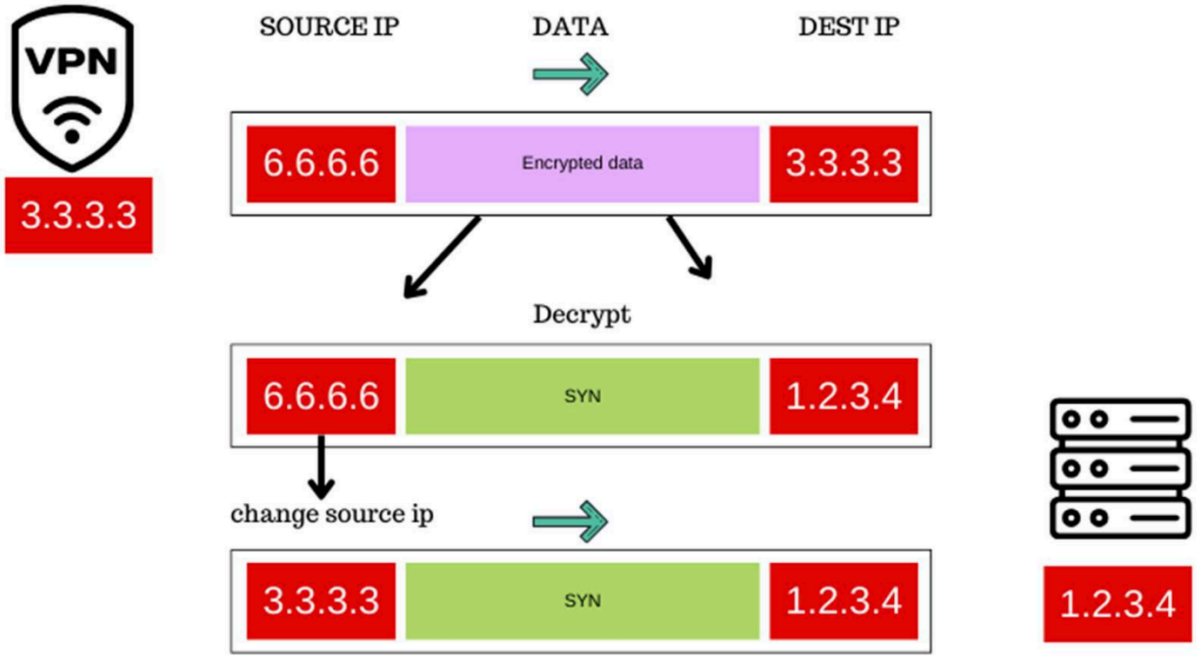
Apertura connessione tcp



Pacchetti UDP



Apertura connessione TCP dal server


VPN
3.3.3.3
SOURCE IP
DATA
DEST IP
6.6.6.6
Encrypted data
3.3.3.3
Decrypt
6.6.6.6
SYN
1.2.3.4
change source ip
3.3.3.3
SYN
1.2.3.4
1.2.3.4